WEBSITE VULNERABILITY ASSESSMENT REPORT

Altoro Mutual / demo.testfire.net

PREPARED BY

QUSAY ALHEMIRY

ASSESSMENT DATE

03 NOVEMBER 2026

ENGAGEMENT

Future Interns - Cyber Security Task 1

TARGET TYPE

Public demonstration website

EXECUTIVE SUMMARY

A limited security review of the Altoro Mutual demonstration website identified four configuration hardening opportunities in sampled public HTTP responses. The assessment used Chrome DevTools, OWASP ZAP passive analysis in Safe Mode, and a separate limited Nmap TCP connection check. No exploit attempts, credential attacks, or authenticated testing were performed.

04	02	02	02
documented findings	medium	low	TCP ports checked

KEY OUTCOMES

F-01	Missing Content Security Policy	Medium
F-02	Missing anti-clickjacking protection	Medium
F-03	Server identification disclosure	Low
F-04	Missing HSTS policy	Low

EDUCATIONAL ASSESSMENT | NOT A FULL PENETRATION TEST

01 - APPROACH

Scope, tools and exposure checks

Target and assessment boundaries

Target	https://demo.testfire.net/?mode=demo
Public pages sampled	Home and About Us (/index.jsp?content=inside_about.htm)
Allowed web work	Read-only page review, response-header and cookie inspection
Excluded	Login bypass, exploitation, brute force, DoS, active ZAP attacks

Methodology

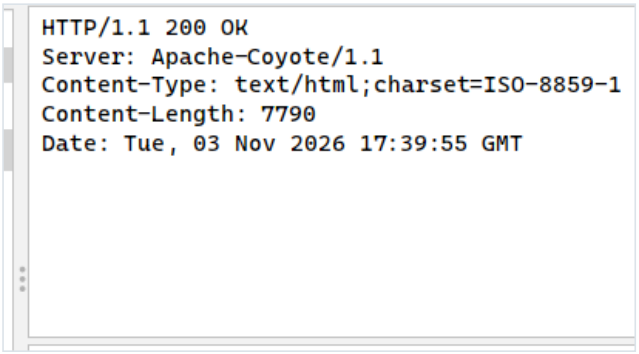
01 **Chrome DevTools**
Reviewed response headers on public pages and observed session cookie flags.

02 **OWASP ZAP 2.17.0**
Manual Explore in Safe Mode; passive alerts corroborated header observations.

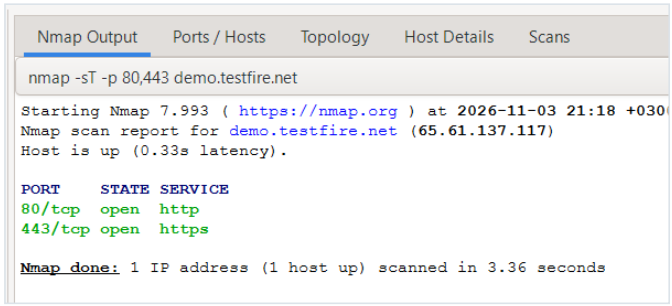
03 **Nmap 7.993**
Limited active TCP connect scan of ports 80 and 443 only; no broad sweep.

Network exposure: 65.61.137.117 was reachable. Both **80/tcp (HTTP)** and **443/tcp (HTTPS)** were open at scan time. An open port alone does not indicate a vulnerability.

Evidence - captured responses and Nmap output



E03 Original 200 OK response headers



E09 Limited TCP port-check output

Interpretation: The sampled response headers and two port statuses cannot establish the overall security posture of the application. Nmap connections are active checks and are explicitly distinguished from passive web analysis.

02 - OBSERVATIONS

Medium risk findings

ZAP risk categories are reported for transparency. They describe potential exposure, not demonstrated successful attacks.

F-01 Content Security Policy not set

MEDIUM

ZAP confidence: High

Observation. The sampled HTML response did not include an enforcing **Content-Security-Policy** header.

Evidence. ZAP passive alert 10038 and direct response-header inspection.

Potential impact. Without a restrictive policy, malicious injected content may face fewer browser-side restrictions if a separate injection weakness exists. This is not proof of XSS.

Recommendation. Define, test and deploy a tailored CSP appropriate to the application resources.



F-02 Anti-clickjacking protection absent

MEDIUM

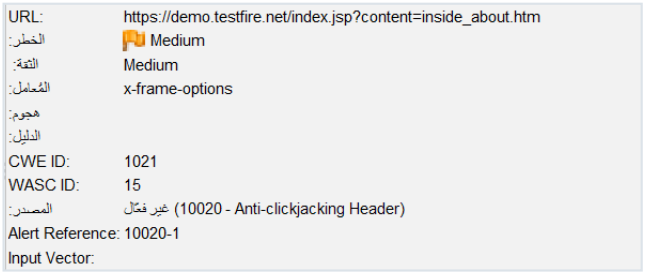
ZAP confidence: Medium

Observation. The About Us response contains neither **X-Frame-Options** nor CSP **frame-ancestors**.

Evidence. ZAP passive alert 10020; corroborated by the original HTML response headers.

Potential impact. The page may be framed by an unrelated site, increasing the risk of deceptive click interaction. No attack was attempted.

Recommendation. Set **frame-ancestors 'self'** or **'none'** as appropriate; consider X-Frame-Options for legacy clients.



03 - OBSERVATIONS

Low risk findings

These are configuration improvements. No vulnerable server build, downgrade attack, or private data exposure was proven.

F-03 Server information disclosure

LOW

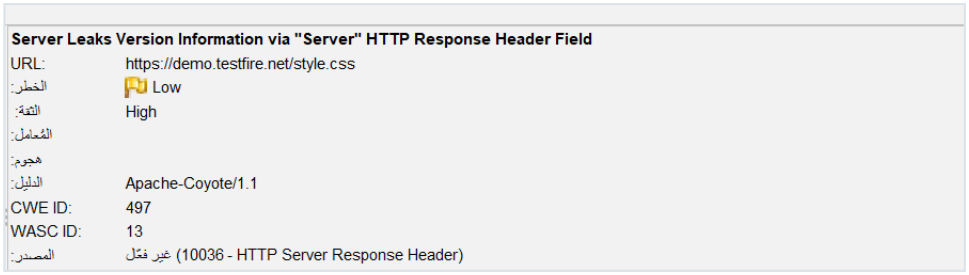
ZAP confidence: High

Observation. The response included **Server: Apache-Coyote/1.1** in its header.

Evidence. ZAP passive alert 10036; the same server identification is visible in the HTTP response.

Potential impact. A technology banner can support reconnaissance, but the banner does not establish the actual software release or show that it is outdated.

Recommendation. Reduce unnecessary Server header detail and maintain a documented patching process.



F-04 HSTS policy not set

LOW

ZAP confidence: High

Observation. The inspected HTTPS response did not include a **Strict-Transport-Security** header.

Evidence. ZAP passive alert 10035, supported by the observed response headers.

Potential impact. Without a previously stored HSTS policy, some initial HTTP connections may lack automatic upgrade protection. The site did respond over HTTPS.

Recommendation. After validating reliable HTTPS, set a suitable HSTS policy and carefully assess its duration and subdomain coverage.

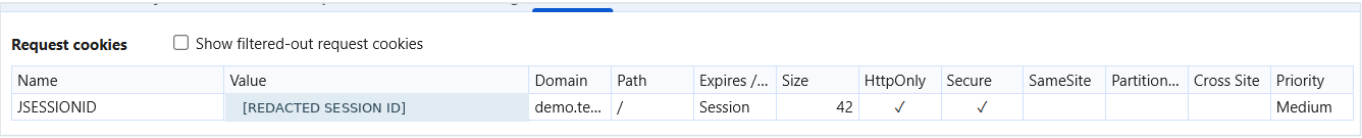


04 - SUPPORTING CHECKS

Cookie, cache and response review

Session cookie configuration

Chrome DevTools displayed **JSESSIONID** with **HttpOnly** and **Secure** enabled. **SameSite** was not explicitly listed; browser defaults may apply. No cookie theft or CSRF was demonstrated.



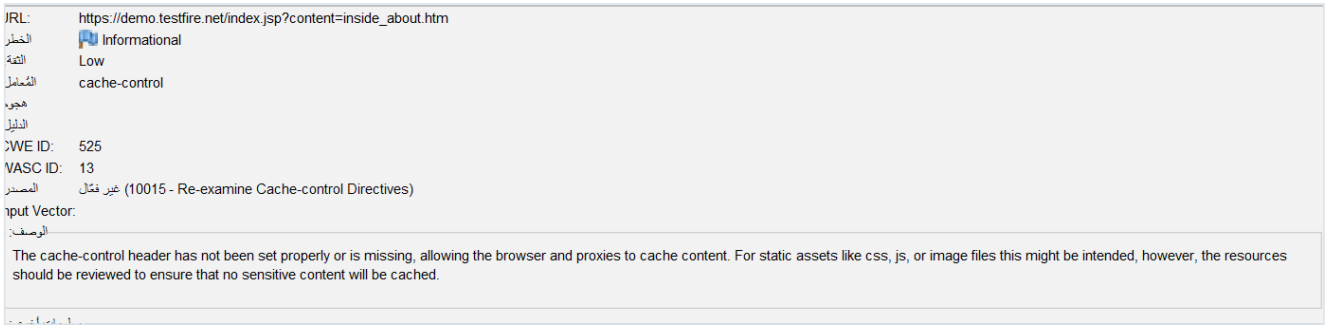
Request cookies ☐ Show filtered-out request cookies

Name	Value	Domain	Path	Expires /...	Size	HttpOnly	Secure	SameSite	Partition...	Cross Site	Priority
JSESSIONID	[REDACTED SESSION ID]	demo.te...	/	Session	42	✓	✓				Medium

E10 Cookie settings; session value permanently redacted

Cache-control advisory

ZAP flagged a cache-control review on the public About Us page as **Informational** with **Low confidence**. This is a review recommendation, not evidence that sensitive data was cached.

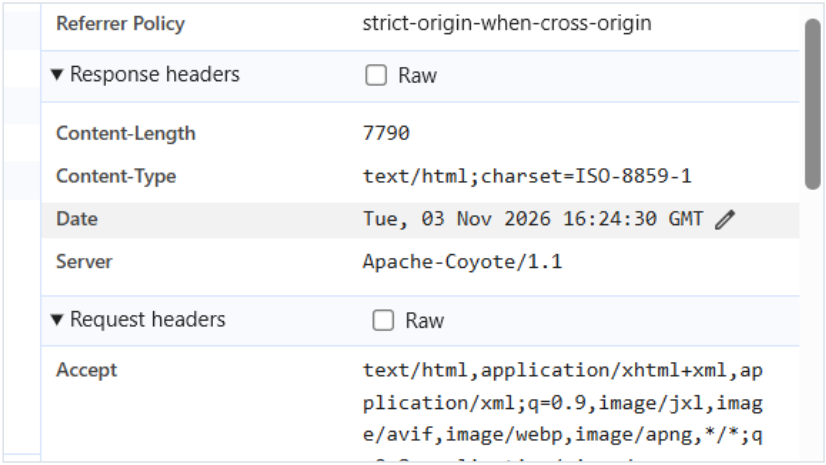


URL: https://demo.testfire.net/index.jsp?content=inside_about.htm
الخطر: Informational
الثقة: Low
المعامل: cache-control
هجوم:
الدليل:
CWE ID: 525
WASC ID: 13
المصدر: غير فعّال (10015 - Re-examine Cache-control Directives)
Input Vector:
الوصف:
The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.

E08 Informational cache-control alert

Direct response-header corroboration

The browser showed an HTTP 200 response with the Server header and no CSP, HSTS or framing protections in the inspected About Us response.



Referrer Policy	strict-origin-when-cross-origin
▼ Response headers	☐ Raw
Content-Length	7790
Content-Type	text/html;charset=ISO-8859-1
Date	Tue, 03 Nov 2026 16:24:30 GMT
Server	Apache-Coyote/1.1
▼ Request headers	☐ Raw
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,image/jxl,image/avif,image/webp,image/apng,*/*;q

E02 Chrome DevTools header inspection - About Us

05 - RECOMMENDATIONS

Remediation plan and conclusions

Prioritized actions

01	**Content security** Deploy a tested CSP based on legitimate content sources.
02	**Framing restrictions** Use CSP frame-ancestors and appropriate legacy fallback.
03	**Encrypted transport** Validate HTTPS-first operation, then apply a suitable HSTS policy.
04	**Reduce exposure** Minimize technology disclosure in the Server response header.
05	**Session and caching** Set explicit SameSite where appropriate; prevent caching of sensitive pages.

Evidence package / GitHub deliverables

The public repository includes **Vulnerability_Assessment_Report.pdf**, the **Evidence/** folder with labelled screenshots, and **README.md** describing the website, scope, tools, findings and limitations.

Limits of this review

- Only the sampled public pages and their observed responses were assessed; authenticated or sensitive workflows were not examined.
- No active ZAP attacks, exploitation, password testing or denial-of-service activity were performed.
- The Nmap check was a separate, limited active TCP test of 80 and 443; it does not identify vulnerabilities by itself.
- Findings describe observed controls and plausible risks, not proven compromise or a complete independent audit.

Conclusion

This training assessment records **four evidence-supported security configuration observations** and provides practical remediation guidance. Further authorized assessment is needed to determine exploitability and overall risk.

REFERENCE DOCUMENTS

Future Interns - Cyber Security Task 1 (2026): futureinterns.com/cyber-security-task-1-2026/

OWASP ZAP: zaproxy.org | Nmap: nmap.org | Demo application: demo.testfire.net